

Tecnológico Nacional de México

Campus Saltillo

Ingeniería en Sistemas Computacionales

Computo en la nube

4.2 Demostrar la inyección SQL

Docente: Ing. Miguel Salazar del Bosque

Equipo:

Hugo Emilio Espinoza Tun 22050627

Contents

Paso 1: Preparar el entorno	1
Paso 2: Crear la Aplicación vulnerable.....	2
Paso 3: Realizar la inyección SQL	3
Paso 4: Mitigación de la inyección SQL.....	4



Paso 1: Preparar el entorno

Se creó la base de datos vulnerable_db con la tabla usuarios y registros de prueba.

```
hugo@debian:~$ mysql -u root -p
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.8.3-MariaDB-0+deb13u1 from Debian -- Please help get to 1
0k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statemen
t.

MariaDB [(none)]> show databases;
+-----+
| Database |
+-----+
| cnube    |
| information_schema |
| mysql    |
| performance_schema |
| sys      |
+-----+
5 rows in set (0.010 sec)

MariaDB [(none)]> CREATE DATABASE vulnerable_db;
Query OK, 1 row affected (0.002 sec)

MariaDB [(none)]> USE vulnerable_db;
Database changed
MariaDB [vulnerable_db]> CREATE TABLE usuarios (
  -> id INT AUTO_INCREMENT PRIMARY KEY,
  -> nombre_usuario VARCHAR(50),
  -> contrasena VARCHAR(50)
  -> );
Query OK, 0 rows affected (0.051 sec)

MariaDB [vulnerable_db]> INSERT INTO usuarios (nombre_usuario, contrasena) V
ALUES ('admin', '1234');
(nombre_usuarioQuery OK, 1 row affected (0.007 sec)

MariaDB [vulnerable_db]> INSERT INTO usuarios (nombre_usuario, contrasena) V
ALUES ('user', 'password');
Query OK, 1 row affected (0.005 sec)

MariaDB [vulnerable_db]> |
```

```
srvdb [Comando] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

Debian GNU/Linux 13 debian tty1
debian login: hugo
Password:
Linux debian 6.12.69+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.69-1 (2026-02-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.

1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp3s1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:12:34:56 brd ff:ff:ff:ff:ff:ff
    altname enp3s1v27123456
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute enp3s1
        valid_lft 86397sec preferred_lft 75507sec
    inet6 fd11:2445:1001::1001/64 scope global dynamic mngtaddr noprefixroute
        valid_lft 86303sec preferred_lft 14303sec
    inet6 fe80::208:1ff:fe00:4556/64 scope link
        valid_lft forever preferred_lft forever
3: enp3s8: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:12:34:56 brd ff:ff:ff:ff:ff:ff
    altname enp3s8v27123456
    inet 192.168.56.30/24 brd 192.168.56.255 scope global enp3s8
        valid_lft forever preferred_lft forever
    inet6 fe80::208:1ff:fe00:4556/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
hugo@debian:~$
```



Paso 2: Crear la Aplicación vulnerable

Se creó la base de datos vulnerable_db con la tabla usuarios y registros de prueba.

```
hugo@debian: /var/www/htr  ×  +  ▾
GNU nano 8.4 login.php *
<?php
$conn = new mysqli('localhost', 'root', '', 'vulnerable_db');

if ($conn->connect_error) {
    die("Connection failed: " . $conn->connect_error);
}

if ($_SERVER['REQUEST_METHOD'] == 'POST') {
    $usuario = $_POST['usuario'];
    $contrasena = $_POST['contrasena'];

    // Consulta vulnerable
    $sql = "SELECT * FROM usuarios WHERE nombre_usuario='$usuario' AND contrasena='$contrasena'";
    $result = $conn->query($sql);

    if ($result->num_rows > 0) {
        echo "Login exitoso";
    } else {
        echo "Credenciales inválidas";
    }
}
?>

<form method="POST" action="login.php">
    Usuario: <input type="text" name="usuario"><br>
    Contraseña: <input type="password" name="contrasena"><br>
    <input type="submit" value="Ingresar">
</form>
```

Legend:

^G Help	^O Write Out	^F Where Is	^K Cut	^T Execute
^X Exit	^R Read File	^N Replace	^U Paste	^J Justify



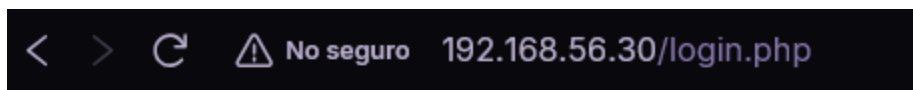
Paso 3: Realizar la inyección SQL

Se desarrolló un formulario de login vulnerable utilizando admin ' -- directa en la consulta SQL.



Usuario:

Contraseña:



Usuario:

Contraseña:



Login exitoso

Usuario:

Contraseña:

Paso 4: Mitigación de la inyección SQL

Se realizó una inyección SQL utilizando admin' --, logrando autenticarse sin contraseña.

Después de la mitigación, la inyección SQL dejó de funcionar.

```
hugo@debian: ~
hugo@debian: /var/www/htr
hugo@debian: /var/www/html
GNU nano 8.4 login.php *
<?php
// Mostrar errores (para debug)
mysqli_report(MYSQLI_REPORT_ERROR | MYSQLI_REPORT_STRICT);
error_reporting(E_ALL);
ini_set('display_errors', 1);

// Conexión a la BD (SRVBD)
$conn = new mysqli('192.168.56.30', 'login_user', '1234', 'vulnerable_db');

// Verificar conexión
if ($conn->connect_error) {
    die("Error de conexión: " . $conn->connect_error);
}

// Procesar formulario
if ($_SERVER['REQUEST_METHOD'] == 'POST') {
    $usuario = $_POST['usuario'];
    $contrasena = $_POST['contrasena'];

    $stmt = $conn->prepare("SELECT * FROM usuarios WHERE nombre_usuario=? AND contrasena=?");
    $stmt->bind_param("ss", $usuario, $contrasena);
    $stmt->execute();

    $result = $stmt->get_result();

    if ($result && $result->num_rows > 0) {
        echo "Login exitoso";
    } else {
        echo "Credenciales inválidas";
    }
}

?>

<form method="POST" action="login.php">
    Usuario: <input type="text" name="usuario"><br>
    Contraseña: <input type="password" name="contrasena"><br>
    <input type="submit" value="Ingresar">
</form>

^G Help      ^O Write Out  ^F Where Is   ^K Cut        ^T Execute    ^C Location
^X Exit      ^R Read File  ^\ Replace    ^U Paste      ^J Justify    ^_ Go To Line
```

Login exitoso

Usuario:

Contraseña: